

AWS Penetration Testing Engagement Requirements

Document Purpose: This specification outlines the technical prerequisites required to conduct a safe, effective, and compliant penetration testing engagement against your AWS environment. Each requirement includes a clear business justification to ensure alignment between security objectives and operational constraints.

ACCOUNT & CREDENTIAL REQUIREMENTS

Preferred Authentication Method: Cross-Account IAM Role

Requirement	Technical Specification	Business Justification
Authentication Mechanism	Cross-account IAM Role with <code>sts:AssumeRole</code> trust relationship	Provides temporary, auditable credentials that automatically expire, eliminating the risk of long-term credential leakage
Trust Policy Configuration	Trust policy must explicitly allow our testing AWS account ARN: <code>arn:aws:iam::[OUR_ACCOUNT_ID]:root</code>	Ensures only authorized personnel can assume the role; prevents unauthorized access if role ARN is inadvertently exposed
Session Duration	Maximum session duration: 4 hours (configurable via <code>MaxSessionDuration</code>)	Limits potential blast radius if credentials are compromised; aligns with industry best practices for privileged access

MFA Enforcement	Role assumption must require MFA via <code>aws:MultiFactorAuthPresent</code> condition	Adds critical second factor of authentication; required by most compliance frameworks (SOC 2, ISO 27001, PCI DSS)
------------------------	--	---

Why This Approach Is Required:

AWS security best practices explicitly recommend using IAM roles with temporary credentials instead of long-term access keys for both human users and workloads . For penetration testing engagements, this approach provides three critical advantages:

1. **Auditability:** Every action is logged in CloudTrail with the assuming principal's identity, enabling precise forensic analysis
2. **Revocability:** Access can be instantly terminated by modifying the trust policy—no key rotation required
3. **Least Privilege Enforcement:** Permissions are scoped to the engagement scope and automatically expire

Implementation Template (Client to Provide):

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "AWS": "arn:aws:iam::[YOUR_TESTING_FIRM_ACCOUNT_ID]:root"
      },
      "Action": "sts:AssumeRole",
      "Condition": {
        "Bool": {
          "aws:MultiFactorAuthPresent": "true"
        },
        "StringEquals": {
          "aws:SourceAccount": "[CLIENT_ACCOUNT_ID]"
        }
      }
    }
  ]
}
```

IAM Permissions Framework: Layered Access Model

We require a **two-layer permission structure** to balance testing effectiveness with risk mitigation:

Layer 1: Foundational Read-Only Access (Mandatory)

Policy: Attach AWS-managed [SecurityAudit](#) policy

Purpose	Technical Scope	Risk Mitigation
Security posture assessment	Read-only access to configuration metadata across 100+ AWS services (EC2, S3, IAM, CloudTrail, Config, etc.)	Prevents accidental modification of production resources during reconnaissance phase
Compliance validation	Enables verification of encryption settings, logging configuration, network security groups	Supports regulatory reporting requirements without exposing sensitive data
Attack surface mapping	Discovers publicly accessible resources, IAM policies, trust relationships	Identifies exposure points before exploitation testing begins

 The [SecurityAudit](#) policy is AWS-maintained and regularly updated to include new services. It grants **zero write permissions**, making it safe for initial engagement setup .

Layer 2: Scoped Exploitation Permissions (Engagement-Specific)

Policy: Custom inline policy attached to the testing role with explicit resource scoping

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ExploitationTesting",
      "Effect": "Allow",
      "Action": [
```

```

    "ec2:RunInstances",
    "ec2:CreateSnapshot",
    "ec2:ModifyInstanceAttribute",
    "iam:PassRole",
    "lambda:InvokeFunction",
    "lambda:UpdateFunctionCode",
    "s3:PutObject",
    "s3:DeleteObject",
    "secretsmanager:GetSecretValue",
    "ssm:GetParameter",
    "sts:AssumeRole"
  ],
  "Resource": [
    "arn:aws:ec2:*:[CLIENT_ACCOUNT_ID]:instance/*",
    "arn:aws:iam::[CLIENT_ACCOUNT_ID]:role/Pentest-*",
    "arn:aws:s3:::client-pentest-*",
    "arn:aws:lambda:*:[CLIENT_ACCOUNT_ID]:function:test-*"
  ],
  "Condition": {
    "StringEquals": {
      "aws:ResourceTag/EngagementScope": "Pentest-2026-Q2"
    },
    "DateLessThan": {
      "aws:CurrentTime": "2026-06-30T23:59:59Z"
    }
  }
},
{
  "Sid": "ExplicitDenyDestructiveActions",
  "Effect": "Deny",
  "Action": [
    "ec2:TerminateInstances",
    "rds>DeleteDBInstance",
    "s3>DeleteBucket",
    "cloudtrail:StopLogging",
    "cloudtrail>DeleteTrail",
    "guardduty>DeleteDetector",
    "organizations:*"
  ],
  "Resource": "*"
}
]
}

```

Critical Permission Requirements & Justifications:

Permission	Why Required for Testing	Risk if Omitted
<code>iam:PassRole</code>	Required to test 15+ documented IAM privilege escalation paths where attackers abuse roles passed to services like Lambda, EC2, or Glue	Cannot validate if misconfigured roles enable privilege escalation—a top AWS breach vector
<code>sts:AssumeRole</code>	Enables testing of role chaining, cross-account trust misconfigurations, and lateral movement paths	Misses critical attack paths where attackers pivot between roles/accounts
<code>ec2:ModifyInstanceAttribute</code>	Tests exposure of instance metadata service (IMDSv1/v2), user data secrets, and instance profile abuse	Cannot validate SSRF-to-instance-compromise scenarios
<code>s3:PutObject/DeleteObject</code>	Validates bucket policy effectiveness, ACL misconfigurations, and data exfiltration paths	Misses data exposure risks that are among the most common AWS findings
Explicit Deny on destructive actions	Prevents accidental termination of production resources during testing	Mitigates business disruption risk; required by most enterprise risk policies

Resource Scoping Requirements:

- **ARN Patterns:** All resources must be scoped using explicit ARN patterns (e.g., `arn:aws:s3:::client-prod-*`) rather than wildcards (*)
- **Tag-Based Filtering:** Resources should be tagged with `EngagementScope=Pentest-2026-Q2` to enable dynamic scoping as infrastructure changes

- **Time-Bound Conditions:** All write permissions must include **DateLessThan** conditions to auto-expire access post-engagement

⚠ Critical Note: Permissions must follow the **principle of least privilege**. Overly permissive policies increase risk without improving test quality. We will validate permissions during pre-engagement testing and request adjustments if scope is insufficient .

Credential Delivery & Management Protocol

Method	Security Controls	When to Use
AWS Secrets Manager + Temporary Session	• Credentials encrypted at rest and in transit • Access logged via CloudTrail • Automatic rotation capability • Fine-grained IAM access policies	✅ Preferred for all enterprise engagements

Encrypted Email (PGP/GPG)	• End-to-end encryption • Key expiration enforcement • Signed verification of sender identity	 Acceptable for short-duration engagements (<7 days) with documented key management process
Secure Client Portal Transfer	• Portal requires MFA • Files encrypted with client-provided passphrase • Access logs maintained	 Acceptable if client has approved secure file transfer system
Plain Text Transmission	• No encryption • No audit trail	 Prohibited under all circumstances

	• High leakage risk	
--	---------------------	--

Credential Lifecycle Requirements:

1. **Generation:** Credentials must be generated specifically for this engagement (no reuse of existing keys)
2. **Transmission:** Must use one of the approved secure methods above
3. **Activation:** Credentials become active only after written confirmation of scope acceptance
4. **Expiration:** All credentials must auto-expire within 24 hours of engagement end date
5. **Revocation:** Client retains right to immediately revoke access via IAM policy modification at any time



SCOPE DEFINITION REQUIREMENTS

Account & Resource Boundary Specification

Scope Element	Required Format	Why This Precision Is Required	Example
AWS Account IDs	12-digit numeric format, one per line	AWS resources are account-scoped; testing outside authorized accounts violates AWS policy and may impact other customers	123456789012 987654321098

AWS Organizations Structure	OU IDs or account aliases if using AWS Organizations	Ensures testing respects organizational boundaries and delegated administration models	OU: Production (ou-abc123-def456)
AWS Regions	Region codes in ISO format (e.g., us-east-1)	AWS resources are region-isolated; missing a region creates blind spots in security assessment	us-east-1, eu-west-1, ap-southeast-2
Resource Tag Filters	Key=value pairs for dynamic scoping	Enables testing of newly deployed resources without manual scope updates; critical for agile environments	Environment=Production, DataClassification=Confidential
VPC CIDR Blocks	CIDR notation for network-layer testing	Required for network vulnerability scanning; prevents accidental scanning of unrelated infrastructure	10.10.0.0/16, 172.31.0.0/16
Service Endpoints	Fully qualified domain names or ARNs for API testing	Ensures testing targets only authorized application endpoints	api.client-domain.com, arn:aws:apigateway:us-east-1::restapis/abc123

Why Precise Scoping Matters:

AWS operates a multi-tenant infrastructure where customer resources share underlying hardware. Testing resources outside the agreed scope could:

- Violate AWS Customer Agreement terms
- Impact other AWS customers' services
- Trigger automated abuse detection systems
- Create legal liability for both parties

Precise scoping ensures testing remains within your authorized boundary while providing comprehensive coverage of in-scope assets.

Explicit Out-of-Scope Definitions

Category	Specific Examples	Business Risk if Tested	Required Approval Path
Production Databases	RDS instances tagged <code>DataClassification=Confidential</code> , DynamoDB tables with PII	Accidental data exposure, corruption, or compliance violation (GDPR, HIPAA)	CISO + Data Protection Officer written approval
Third-Party SaaS Integrations	Salesforce, Auth0, Datadog connected via IAM roles or API keys	Legal liability; testing requires separate authorization from third-party vendor	Vendor authorization + client legal approval
Denial-of-Service Activities	Load testing, request flooding, port scanning beyond agreed rate limits	Violates AWS policy; may trigger service suspension or impact other customers	AWS Support approval via Simulated Events form (minimum 14 days advance)

Social Engineering	Phishing simulations, physical security testing, pretexting calls	Requires separate engagement type, legal review, and employee consent protocols	Legal department + HR approval + separate SOW
AWS Control Plane	Testing AWS service APIs directly (e.g., exploiting S3 service logic)	Prohibited by AWS Terms of Service; testing AWS infrastructure is never permitted	Not permitted under any circumstances
Disaster Recovery Systems	Backup systems, failover environments, DR drills	Could interfere with business continuity capabilities	CIO + Business Continuity Manager approval

Documentation Requirement:

All out-of-scope items must be documented in the Statement of Work with explicit justification. Ambiguity in scope boundaries is the leading cause of engagement disputes and incomplete security assessments.

Testing Window & Operational Coordination

Requirement	Specification	Business Impact Mitigation
Testing Hours	Defined UTC time windows aligned with client change management policies	Prevents testing during peak business hours; reduces risk of user impact

Rate Limiting Agreement	Maximum requests per second (RPS) per endpoint with burst allowances	Prevents triggering WAF/IDS false positives; avoids resource exhaustion
Source IP Allowlisting	Static IP addresses or CIDR blocks for tester infrastructure	Enables client security teams to distinguish testing traffic from real attacks
Emergency Stop Protocol	Defined communication channel and response time for halting testing	Ensures rapid response if testing causes unexpected system behavior
Monitoring Coordination	Agreement on which CloudWatch alarms/SIEM rules to suppress during testing	Prevents alert fatigue; ensures real incidents remain visible

Sample Operational Parameters:

Testing Window:

- Primary: Monday-Friday, 22:00-06:00 UTC
- Secondary: Weekends, 00:00-23:59 UTC (with 24h advance notice)

Rate Limiting:

- Web APIs: ≤10 RPS sustained, ≤50 RPS burst (max 60 seconds)
- Network Scanning: ≤100 packets/second per target subnet
- Authentication Testing: ≤5 attempts/minute per account

Emergency Contact:

- Primary: security-emergency@client.com (response <15 minutes)
- Secondary: +1-555-0199 (SMS-capable, response <5 minutes)

Source IPs for Allowlisting:

- Primary Testing Infrastructure: 203.0.113.10/32
- Backup Infrastructure: 198.51.100.25/32

Pre-Engagement Validation Checklist

Before active testing commences, we will perform these validation steps **with your confirmation**:

Validation Step	Command/Method	Success Criteria
Account Ownership Verification	<code>aws sts get-caller-identity --profile pentest</code>	Returns expected Account ID and Role ARN
Permission Smoke Test	<code>aws iam get-account-authorization-details --max-items 1</code>	Returns expected policy attachments without errors
Resource Accessibility	<code>aws ec2 describe-instances --filters "Name=tag:EngagementScope,Values=Pentest-2026-Q2"</code>	Returns expected in-scope instances
Network Connectivity	<code>telnet target-api.execute-api.[region].amazonaws.com 443</code>	Successful TLS handshake to in-scope endpoints
Logging Verification	Check CloudTrail for <code>AssumeRole</code> events from testing account	Events appear within 5 minutes of role assumption

 **Client Action Required:** Please confirm completion of these validations via email before we proceed to active exploitation testing.

CLIENT ACTION SUMMARY

To enable a successful engagement, please provide:

For Account Access:

- ☐ Cross-account IAM Role ARN with properly configured trust policy
- ☐ Confirmation that role has **SecurityAudit** policy + custom exploitation policy attached
- ☐ Preferred credential delivery method selection (Secrets Manager recommended)
- ☐ MFA enforcement confirmation for role assumption

For Scope Definition:

- ☐ List of in-scope AWS Account IDs (12-digit format)
- ☐ In-scope AWS Regions and resource tag filters
- ☐ Explicit list of out-of-scope services/resources with business justification
- ☐ Approved testing window and rate limiting parameters
- ☐ Emergency contact information and source IP allowlist

 **Timeline Note:** Please provide these items at least **5 business days** before the scheduled engagement start date to allow for validation and setup.

 **Compliance Alignment:** This specification aligns with requirements from SOC 2 Type II, ISO 27001, NIST SP 800-115, and PCI DSS v4.0 for cloud security assessments.

Should you require clarification on any requirement or assistance implementing the IAM policies described above, our team is available to provide technical guidance at no additional cost during the scoping phase.